

MongoBleed

Cyber Threat Intelligence Case Study

Author: Leonard Okyere Afeke

Date: February 8, 2026

This report is based entirely on publicly available information (OSINT). No scanning, exploitation, or interaction with live systems occurred.

Executive Summary

MongoBleed is a long-running pattern of opportunistic attacks targeting **publicly exposed MongoDB instances** left accessible without authentication. Attackers rapidly scan the internet for open databases, delete stored data, and leave ransom notes claiming the data has been “backed up.” Public reporting consistently shows these claims are false — the attacks result in **irreversible data loss**.

This report synthesizes publicly available information to provide a structured Cyber Threat Intelligence (CTI) assessment of MongoBleed, including attacker behavior, infrastructure patterns, ransom note characteristics, and defensive recommendations.

MongoBleed demonstrates the ongoing risks of cloud misconfiguration and highlights the need for continuous exposure monitoring, secure defaults, and strong access controls.

1 Key Judgments

- MongoBleed is **not a single threat actor**, but a recurring pattern of opportunistic exploitation performed by multiple low-sophistication groups.
- Attackers rely heavily on **automated scanning** to identify exposed MongoDB instances within minutes of exposure.
- Infrastructure used in these attacks is typically **short-lived VPS servers**, often clustered around specific ASNs.
- Ransom notes follow **highly consistent templates**, with repeated claims of data backup and Bitcoin payment demands.
- Public reporting shows **no evidence** that attackers store or back up victim data; restoration is effectively impossible.
- MongoBleed attacks are **destructive extortion**, not true ransomware.
- The threat persists due to **misconfigurations**, not software vulnerabilities.

2 Threat Overview

MongoBleed occurs when MongoDB instances are deployed:

- without authentication
- exposed directly to the internet
- using legacy or insecure defaults
- without firewall or security group restrictions

Attackers exploit these conditions by:

- scanning TCP/27017
- connecting anonymously
- enumerating databases
- deleting data
- inserting ransom notes

This attack chain is simple, automated, and highly scalable.

3 Observed Attacker Behavior

Discovery

Public reporting (e.g., Rapid7, Shodan) shows attackers use:

- automated internet-wide scanning
- search engines indexing exposed services
- scripts that test for unauthenticated access

Exploitation

Once an exposed instance is found:

- attackers connect without credentials
- enumerate databases
- delete collections
- create ransom note collections

Post-Exploitation

Attackers typically:

- do not maintain persistence
- do not monitor payments
- do not store victim data

MongoBleed campaigns are **short-cycle and disposable**.

4 Ransom Note Characteristics

Public OSINT sources show that ransom notes follow a consistent structure.

Common Phrases (short excerpts)

“Your database has been backed up. . .”

“Send X BTC to the following address. . .”

Paraphrased Summary

Ransom notes typically:

- claim the attacker exported the victim’s data
- demand Bitcoin for restoration
- provide a wallet and contact method
- threaten permanent data loss

Reconstructed Template

READ_ME

Your database has been backed up.

To recover your data, send X BTC to [WALLET_ADDRESS].

After payment, contact us at [EMAIL/TELEGRAM].

If you do not pay, your data will be permanently deleted.

Key Insight

Public reporting (e.g., BleepingComputer, Rapid7) shows **no evidence** that attackers store or back up data. Restoration is impossible.

5 Infrastructure Analysis

VPS Usage

Attackers frequently use VPS providers such as:

- DigitalOcean
- OVH
- Hetzner
- Linode

These providers enable:

- low-cost automation
- rapid provisioning
- disposable infrastructure

ASN Clustering

Scanning IPs often cluster around specific ASNs, indicating:

- repeated use of the same hosting provider
- automated deployment across multiple IPs

Geographic Distribution

Infrastructure is globally distributed, reflecting hosting provider availability rather than attacker origin.

6 MITRE ATT&CK Mapping

Phase	Technique	Description
Reconnaissance	Active Scanning (T1595)	Automated scanning of TCP/27017
Resource Development	Acquire Infrastructure (T1583.003)	Use of VPS providers
Initial Access	Exploit Public-Facing Application (T1190)	Accessing unauthenticated MongoDB
Discovery	Query Databases (T1505.003)	Enumerating databases and collections
Impact	Data Destruction (T1485)	Dropping databases
Impact	Defacement (T1491)	Creating ransom note collections

7 Defensive Recommendations

1. Preventive Controls

- Enable MongoDB authentication
- Bind MongoDB to localhost or private networks
- Restrict access using firewalls or cloud security groups
- Disable legacy configuration defaults
- Use managed database services with secure defaults

2. Detection Opportunities

- Anonymous access attempts
- Unexpected connections to TCP/27017
- Rapid database deletion events

- Creation of suspicious collections (e.g., “READ_ME”)
- Connections from VPS-associated ASNs

3. Hardening Measures

- Enforce role-based access control
- Enable auditing and logging
- Require TLS for all connections
- Continuously scan cloud assets for misconfigurations

8 Conclusion

MongoBleed is a persistent, automated threat driven by cloud misconfigurations rather than sophisticated adversaries. Its impact is severe due to irreversible data loss, rapid exploitation, and widespread exposure of unsecured databases.

Organizations can significantly reduce risk by:

- enforcing authentication
- restricting network exposure
- adopting secure deployment practices
- monitoring for misconfigurations

MongoBleed underscores the importance of **cloud hygiene**, **secure defaults**, and **continuous exposure management**.

Sources Consulted (Public OSINT)

- BleepingComputer — reporting on MongoDB ransom attacks
- Rapid7 — research on exposed databases and opportunistic exploitation
- Shodan Blog — analysis of exposed services and scanning behavior
- Censys — internet-wide exposure insights
- MongoDB Documentation — security best practices and authentication guidance
- Public GitHub repositories — examples of MongoDB ransom scripts
- Comparitech — exposed database research